

Secure Coding Review Report

1. Introduction

Secure coding review is the process of analyzing source code to identify vulnerabilities and insecure programming practices that may expose applications to cyberattacks.

2. Objectives

The objective of this project is to identify security flaws, perform code analysis, and recommend secure coding techniques for safer applications.

3. Selected Application

The selected application is a simple Python login system containing insecure authentication logic and hardcoded credentials.

4. Vulnerabilities Identified

The review identified hardcoded credentials, plaintext password handling, missing input validation, and lack of account protection mechanisms.

5. Vulnerability Analysis

Hardcoded passwords can be easily exposed if source code is leaked. Plaintext password comparison increases the risk of credential theft.

6. Static Analysis Tools

Bandit was used as a static analysis tool to scan Python code for security issues and insecure coding practices.

7. Secure Coding Improvements

The secure version of the application uses bcrypt password hashing and secure password verification mechanisms.

8. Best Practices

Developers should avoid hardcoded credentials, validate user inputs, encrypt sensitive data, and regularly review source code for vulnerabilities.

9. Conclusion

Secure coding practices reduce cybersecurity risks and improve application security. Regular code reviews and security testing are essential.

10. Vulnerability Summary

Vulnerability	Risk Level
Hardcoded Credentials	High
Plaintext Passwords	High
Missing Input Validation	Medium
No Account Lockout	Medium

11. Project Screenshot



12. References

- OWASP Secure Coding Practices
- Bandit Python Security Tool
- Python Security Documentation